

Physical Presence-Based Authentication and Authorization for Cyber-Physical Systems and IoT using LiFi

1st Jose Felix

KIM Labs

Arizona State University

Tempe, Arizona

jmfelix4@asu.edu

2nd Dongha Kim

KIM Labs

Arizona State University

Tempe, Arizona

dongha@asu.edu

3rd Hokeun Kim

KIM Labs

Arizona State University

Tempe, Arizona

hokeun@asu.edu

4th Michel Kinsy

STAM Center, School of Computing and Augmented Intelligence

Arizona State University

Tempe, Arizona

mkinsy@asu.edu

5th Gail-Joon Ahn

School of Computing and Augmented Intelligence

Arizona State University

Tempe, Arizona

gahn@asu.edu

Abstract—LiFi (Light Fidelity) is an emerging optical communication method that transmits data using visible and invisible light modulated imperceptibly to the human eye. While secure access control in IoT environments increasingly demands verification of physical presence, existing wireless approaches — including RF-based protocols such as WiFi and Bluetooth — cannot reliably enforce physical boundaries, as signals propagate beyond intended spaces and remain vulnerable to relay and replay attacks. No widely adopted solution currently exists that binds authorization directly to continuous physical presence in real time. Using a custom embedded receiver built around the RP2350 microcontroller (Raspberry Pi Pico 2) with a photodiode-based analog front end, this system enforces continuous physical alignment between sender and receiver, binding the receiving device to a specific physical location. Session key provisioning and per-device dynamic key rotation are managed through the SST (Secure Swarm Toolkit) IoTAuth framework, delivered exclusively over the LiFi optical channel. The system is validated through a physical prototype achieving authenticated encrypted optical communication at 1 Mbps, with the receiver implemented on a custom PCB designed for direct integration with a mobile robotic platform — demonstrating a practical, real-world application of LiFi in high-security environments, where alternative wireless approaches either cannot enforce physical boundaries or require costly environmental modification to do so. This work establishes that authorization can be bound to continuous physical optical presence, such that access is automatically revoked upon signal interruption, making light itself a verifiable and unforgeable proof of presence.

Index Terms—LiFi, visible light communication, physical presence, authentication, authorization, IoT security, AES-GCM, cyber-physical systems, optical wireless

I. INTRODUCTION

The rapid proliferation of cyber-physical systems (CPS) — in which computational processes are tightly coupled with physical environments and real-world actuation — has

fundamentally expanded the attack surface of modern infrastructure. From autonomous robotics and industrial control systems to smart access control and unmanned aerial vehicles, CPS deployments demand security guarantees that extend beyond traditional network boundaries into the physical world. Modern IoT infrastructure, which forms the sensing and communication backbone of many CPS environments, relies overwhelmingly on radio frequency (RF) wireless protocols — including WiFi (IEEE 802.11), Bluetooth, and Zigbee — to connect and authenticate devices. While these technologies offer broad coverage and ease of deployment, their fundamental physical property of propagating through walls, floors, and physical barriers creates an inherent security limitation: an attacker need not be physically present to intercept, relay, or replay an authorization credential. This property makes RF-based systems structurally incapable of enforcing physical presence as a security boundary without deliberate and costly modification of the physical environment — such as RF shielding, Faraday enclosures, or signal attenuation infrastructure — placing the security burden on architecture rather than protocol design.

Light-emitting diodes (LEDs) have undergone a quiet but transformative proliferation over the past two decades, becoming the dominant illumination technology across virtually every indoor environment. Hospitals, schools, warehouses, office complexes, and government facilities have nearly universally transitioned to LED infrastructure — driven primarily by energy efficiency mandates and cost reduction — yet the full communicative potential of this installed base remains almost entirely untapped. A standard LED can be modulated at frequencies imperceptible to the human eye, switching on and off millions of times per second while maintaining its apparent steady illumination. This property, the foundation of Light Fi-

delity (LiFi) communication, transforms an already-deployed, already-powered, and already-trusted physical infrastructure into a parallel communication and authorization channel — one that requires no additional radio spectrum allocation in an era where RF spectrum congestion is an escalating constraint on wireless capacity.

Every classroom equipped with LED overhead lighting is, in principle, a facility capable of spatially scoped, eavesdrop-resistant communication. Every hospital ward, where RF emissions are already constrained or prohibited near sensitive medical equipment, possesses a ready-built optical network that could simultaneously illuminate and authorize. Every secure government operations center, every industrial floor where RF interference poses operational risk, every access-controlled server room — all represent environments where the convergence of illumination infrastructure and communication security is not merely convenient but architecturally natural. Unlike RF-based approaches, which require deliberate countermeasures to confine their propagation, optical communication is confined by construction: light does not pass through opaque walls, does not propagate around corners without deliberate redirection, and does not travel from one room to the next without physical intervention.

This work exploits that property not solely as a communication channel but as an active security primitive. Rather than treating LiFi as a higher-bandwidth wireless alternative, we reframe the optical signal itself as a verifiable proof of physical presence — one that is continuously asserted, continuously verified, and automatically revoked the moment the optical path between sender and receiver is broken. This shifts the security model from a question of credential possession to a question of physical geometry: authorization is granted not because a device holds a valid key, but because it is, at this moment, in this exact location, receiving light from this specific source.

II. RELATED WORK

A. LiFi as a Communication Technology

The term LiFi was first introduced by Harald Haas in his 2011 TEDGlobal talk [3], where he demonstrated that a standard LED bulb, modulated at speeds imperceptible to the human eye, could transmit data at rates exceeding conventional RF wireless technologies. Since then, the IEEE 802.11bb standard [5], ratified in June 2023, specifies bidirectional optical PHY layers that achieve throughputs between 10 Mb/s and 9.6 Gb/s, operating in the 800 nm to 1000 nm near-infrared band — establishing LiFi as a formally recognized wireless standard with measurable and interoperable performance guarantees. Under experimental conditions, researchers have demonstrated peak data rates of 224 Gb/s [4] — exceeding the fastest commercial Wi-Fi implementations by two orders of magnitude.

B. RF-Based State of the Art

Wi-Fi RSSI fingerprinting represents the most widely deployed RF-based approach to indoor presence estimation, op-

erating by matching a device’s received signal strength profile against a pre-built spatial database. However, the approach is fundamentally probabilistic — RSSI values fluctuate with human movement, temperature variation, multipath propagation, and environmental change, producing positioning errors that routinely reach several meters under real-world conditions. More critically, WiFi signals are designed for broad coverage and penetrate most walls, meaning the authorization boundary does not coincide with the physical boundary of a space. Research has demonstrated that a passive adversary equipped with nothing more than a commodity smartphone can monitor and manipulate RSSI readings from outside a building — without ever accessing the network, the devices, or the space itself. An attacker who can estimate the distance between transmitter and receiver can simply amplify transmission power to spoof a matching RSS value, defeating presence-based authentication from outside the intended boundary. The result is a system where the authorization perimeter exists in software policy, not in physical law — and is therefore subject to manipulation by any sufficiently motivated adversary with commodity hardware.

C. Physical Layer Security

Physical layer security as a formal discipline originates with Wyner’s landmark 1975 wiretap channel model, which demonstrated that secure communication is achievable without a shared secret key when the legitimate receiver’s channel is of higher quality than the eavesdropper’s [1]. This theoretical foundation motivated decades of subsequent work — channel reciprocity key generation, cooperative jamming, and beamforming — all attempting to engineer a favorable channel advantage for legitimate parties over adversaries. However, these approaches share a common ceiling: secrecy capacity in RF environments is highly sensitive to environmental dynamics, multipath propagation, and physical changes, making deterministic security guarantees structurally difficult to achieve regardless of protocol sophistication.

To address relay attacks specifically — where an adversary forwards authentication exchanges to falsely assert physical proximity — Brands and Chaum introduced distance-bounding protocols in 1993, using round-trip signal timing to compute an upper bound on the prover-to-verifier distance [2]. While foundational, these protocols remain vulnerable to mafia fraud and terrorist fraud, and critically, they bound distance without enforcing location — they answer how far but not where. A system confined by the physics of light answers the *where* question directly, without dedicated timing infrastructure. It does not, however, get the *how far* question for free: as discussed in Section IV (G3), the present implementation has no round-trip timing check of its own, so a live optical relay that forwards genuinely fresh frames in real time is not excluded by construction. Combining the location-confinement property demonstrated here with a Brands–Chaum-style timing bound is left as future work (Section VII).

D. VLC and LiFi Security

The security landscape of visible light communication has been surveyed from multiple perspectives. Blinowski [6] provided the first comprehensive review of VLC security, systematically cataloging threats including eavesdropping, jamming, and node compromise, and organizing countermeasures into physical layer security (PLS), key generation, steganography, and conventional cryptographic approaches. Arfaoui et al. [7] extended this with a unified treatment of PLS for VLC from both information-theoretic and signal processing viewpoints, covering channel models, input distributions, precoding strategies, and secrecy capacity analysis. Both surveys conclude that despite the spatial confinement of light, VLC systems remain vulnerable in open areas, multi-user scenarios, and rooms with reflective surfaces or windows — contradicting the common assumption that optical links are inherently eavesdropping-proof.

1) *Information-Theoretic Physical Layer Security*: The dominant thread in VLC security research derives from Wyner's wiretap channel model, adapted to the optical intensity channel. Researchers have characterized the secrecy capacity of VLC links under various constraints — non-negative signaling, peak and average optical power limits, and dimmable illumination requirements — that distinguish VLC from conventional RF analysis. Beamforming techniques using multi-element LED arrays have been proposed to steer optical power toward legitimate receivers while creating nulls at eavesdropper locations [7]. Protected zones — eavesdropper-free regions around the receiver — have been analyzed to quantify the secrecy capacity improvement when physical access control limits how close an adversary can approach [8]. More recently, intelligent reflecting surfaces (IRS) have been introduced to VLC security, enabling dynamic control of the optical propagation environment to simultaneously enhance legitimate signal quality and degrade eavesdropper reception [9].

These approaches share a common limitation: they provide probabilistic secrecy guarantees that depend on channel state information, eavesdropper location models, and assumptions about the spatial distribution of adversaries. They do not provide deterministic, real-time authorization decisions. A legitimate receiver that moves out of the secure zone or loses line-of-sight continues to be “authorized” in any access control sense — the physical layer security only ensures that an eavesdropper in a disadvantaged position cannot decode the signal. No mechanism exists to revoke the receiver's authorization based on its ongoing physical relationship to the transmitter.

2) *Physical Layer Key Generation*: A second active research direction exploits the reciprocity and spatial variability of VLC channels to generate shared secret keys between communicating parties without prior key distribution. Zaman et al. [10] proposed a key generation scheme for inter-vehicular VLC that extracts randomness from channel measurements, achieving key generation rates that vary with the relative positions and velocities of the vehicles. More recently, Al-

Moliki et al. proposed key generation protocols for indoor VLC using OFDM subcarrier measurements, leveraging the spatial dependence of the optical channel to ensure that an eavesdropper at a different location derives a different key [11]. Quantum key distribution over VLC channels has also been explored as an extension to post-quantum security, though practical implementations remain limited to laboratory demonstrations [12].

Physical layer key generation addresses the key establishment problem but does not address continuous authorization. Once a key is generated and shared, the VLC channel's role in the security protocol ends — the key persists independently of whether the optical link is maintained. An adversary who obtains the key through any means (side channel, device compromise, relay during the key generation phase) retains it regardless of physical presence.

3) *VLC-Assisted Device Initialization*: Perković et al. [13] proposed LISA, a multichannel protocol that uses VLC from smartphone screens to securely initialize resource-constrained IoT devices. The visible light channel serves as an out-of-band (OoB) channel for bootstrapping cryptographic credentials, exploiting the assumption that an attacker cannot simultaneously observe the screen and the device without being physically present during the initialization ceremony. This work represents the closest conceptual antecedent to our approach in that it leverages the spatial confinement of light for a security purpose beyond simple data confidentiality. However, LISA uses VLC as a one-time initialization channel — a brief optical ceremony that establishes long-lived credentials. Once initialization is complete, the optical channel plays no further security role, and the device's authorization does not depend on continued optical reception.

4) *Encrypted VLC Implementations*: Several hardware implementations of secure VLC have been demonstrated. Kim et al. [14] implemented an asymmetric RSA-encrypted VLC link using embedded microcontrollers and OOK modulation, achieving secure transmission over short distances with an LED array and photodiode receiver. Liao et al. [15] demonstrated a chaos-synchronized VLC system using Arduino Due microcontrollers, encrypting audio signals with a Rössler chaotic system before optical transmission. These implementations validate that encryption is feasible on resource-constrained VLC hardware, but treat the optical link as a transparent data pipe — the encryption provides confidentiality in transit, but the physical properties of the optical channel are not themselves used as a security mechanism.

5) *Commercial LiFi Security*: Industry deployments have begun to address VLC security at the product level. Signify's Trulifi platform offers FIPS 140-3 validated encryption for LiFi connections, marketing the physical confinement of light as an inherent security advantage over RF [16]. Oledcomm similarly positions LiFi as intrinsically more secure than WiFi due to the non-penetration of light through walls [17]. The LiFi Lab consortium has proposed a LiFi-based access control system combining optical data transmission with biometric authentication [18]. While these commercial systems leverage

the spatial properties of light to reduce the attack surface, they implement conventional authentication models — a device authenticates once and retains access until explicitly revoked by an administrative action or credential expiry. The continuous physical presence of the device within the optical coverage area is not monitored or enforced as a condition of ongoing authorization.

6) *The Gap: Continuous Optical Presence as an Authorization Primitive*: Across the existing literature, VLC security research falls into four categories: (1) information-theoretic analysis of secrecy capacity, which provides statistical guarantees about eavesdropper disadvantage but not real-time authorization; (2) physical layer key generation, which bootstraps shared secrets from channel measurements but decouples the key from ongoing optical presence; (3) encrypted VLC implementations, which protect data in transit but do not exploit the physical channel for access control; and (4) commercial LiFi products, which market spatial confinement as a feature but implement one-time authentication models.

No existing work binds authorization to continuous, time-bounded optical reception with automatic revocation upon signal loss. The concept of presence-based authorization — in which a device is authorized not because it possesses a credential, but because it is, at this moment, receiving authenticated optical transmissions from a specific source — has not been formalized, implemented, or evaluated in the VLC security literature. This is the gap that the present work addresses.

III. SYSTEM ARCHITECTURE

The system comprises three principal subsystems: (1) an optical transmitter built on the RP2040 microcontroller (Raspberry Pi Pico), (2) an optical receiver built on the RP2350 microcontroller (Raspberry Pi Pico 2) with a custom analog front-end, and (3) a key provisioning service based on the SST (Secure Swarm Toolkit) IoTAAuth framework running on a Linux host.

A. Optical Transmitter

The transmitter is responsible for accepting plaintext input, encrypting it under AES-128-GCM, framing the ciphertext with a synchronization preamble and integrity check, and modulating the result onto four LED channels simultaneously via hardware state machines.

1) *PIO-Based Parallel Transmission*: The RP2040’s Programmable I/O (PIO) subsystem is used to implement a custom 8N1 UART transmitter that drives four GPIO pins (GP6–GP9) in lockstep, each connected to a separate LED channel (white, green, blue, red) through a TC4420COA low-side MOSFET gate driver (Microchip, 4.5 A peak output, 8-SOIC) driving a Vishay SIR800DP-T1-GE3 N-channel MOSFET (40 V, 80 A, PPAK) per channel. The LED array operates directly from the 12 V input rail switched by the MOSFET low-side stage. The PIO state machine executes at exactly 8 cycles per bit, yielding deterministic timing with zero CPU involvement during transmission. At a system clock of

125 MHz and a target baud rate of 1 Mbps, the clock divider is set to $125,000,000 / (1,000,000 \times 8) = 15.625$.

The use of four parallel LED channels transmitting identical data provides optical redundancy: the receiver need only detect any one channel, and future work can exploit the independent channels for spatial multiplexing or per-channel encoding.

2) *Sender Power Architecture*: The sender PCB accepts a 12 V DC input through a Würth Elektronik screw-terminal connector. A Texas Instruments PTN78000WAH wide-input DC-DC module (input range 4.5–14 V, output set to 5 V by a 732Ω programming resistor) provides a regulated 5 V supply to the RP2040 VSYS pin, isolating the microcontroller logic from the high-current switching of the LED stage. Input protection is provided by a Littelfuse SMAJ30A 30 V TVS clamp diode and a 3.5 A 1206 chip fuse. Decoupling capacitors (47 μ F and 220 μ F electrolytic, 0.1 μ F ceramic per gate driver) are placed at each switching node to suppress transients.

3) *Cryptographic Pipeline*: Before transmission, each plaintext message passes through the following pipeline:

- 1) **Encryption**. AES-128-GCM is applied using the active session key (16 bytes), producing ciphertext of equal length and a 16-byte authentication tag. The implementation uses mbedTLS, compiled with a minimal configuration that enables only AES, GCM, SHA-256, HMAC, CTR_DRBG, and entropy collection.
- 2) **Nonce construction**. Each nonce (12 bytes) is composed of an 8-byte random salt, generated once per boot from the RP2040’s hardware ring-oscillator PRNG via CTR_DRBG, concatenated with a 4-byte monotonically increasing message counter in big-endian order. This structure guarantees nonce uniqueness both within a boot session (by the counter) and across reboots (by the salt). If the 32-bit counter reaches exhaustion (2^{32} messages), the device initiates an immediate reboot to regenerate the salt, preventing the catastrophic nonce reuse that would compromise GCM confidentiality and authenticity.
- 3) **Framing**. The encrypted payload is prepended with a 4-byte synchronization preamble (0xAB 0xCD 0xEF 0x12), a 1-byte message type identifier, and appended with the 16-byte GCM authentication tag and a 2-byte CRC16-CCITT checksum (polynomial 0x1021, initial value 0xFFFF).

The complete frame structure is:

Preamble	Type	Length	Nonce	Ciphertext	GCM Tag	CRC16
4 B	1 B	2 B	12 B	N B	16 B	2 B

4) *Secure Key Storage*: Session keys are persisted in the RP2040’s on-chip flash using a dual-slot A/B architecture occupying the last three 4 KB sectors of the 2 MB flash. Each slot stores a `key_flash_block_t` structure containing an 8-byte key identifier, the 16-byte AES-128 session key, a 32-byte SHA-256 integrity hash computed over the concatenation of the key identifier and key material, and a 4-byte magic marker (0x53455353, ASCII “SESS”). A separate index sector records which slot was last used.

On boot, the device reads the index sector, attempts to load the indicated slot, validates the magic marker and recomputes the SHA-256 hash to detect partial writes or corruption. If the primary slot fails validation, the alternate slot is tried. If both slots are invalid, the device enters a provisioning mode and awaits a new key over UART. This design ensures that key material survives power loss and that a failed write to one slot does not destroy the previously valid key in the other.

Flash writes are performed with interrupts disabled via `irq_save()` to prevent partial sector erasure, and all sensitive key material in RAM is cleared after use with a `secure_zero()` macro that employs volatile writes to prevent compiler optimization of the erase.

B. Optical Receiver

The receiver converts modulated light back into a digital bitstream using a custom analog front-end, digitizes it through a high-speed comparator, and feeds the result into a PIO-based UART receiver on the RP2350.

1) *Analog Front-End*: The signal chain consists of four stages:

- 1) **Photodetection**. An Osram SFH 2400 silicon PIN photodiode, reverse-biased for speed, converts incident optical power into a photocurrent proportional to illumination intensity.
- 2) **Transimpedance amplification**. A Texas Instruments OPA381AIDGKT precision transimpedance amplifier (8-VSSOP, \$2.93) converts the photocurrent to a voltage. The OPA381 is a purpose-built silicon-input TIA IC featuring an internal feedback architecture that eliminates the input bias-current errors of general-purpose operational amplifiers and provides a stable gain-bandwidth product optimized for photodiode transimpedance applications. The feedback network consists of an external resistor R_f in parallel with a capacitor C_f across the OPA381 feedback pins. The -3 dB bandwidth of the TIA stage is given by:

$$f_{-3\text{dB}} = \frac{1}{2\pi R_f C_f} \quad (1)$$

With $R_f = 100$ k Ω and $C_f = 5$ pF, the bandwidth is approximately 318 kHz, sufficient for reliable reception at 1 Mbps. The output swing is approximately 400 mV under typical illumination conditions at close range.

- 3) **Threshold comparison**. A Texas Instruments TLV3501 high-speed comparator (4.5 ns propagation delay, 80 MHz maximum toggle frequency) converts the analog TIA output to a digital signal. The inverting input (pin 1) receives the TIA output through a 47 Ω series resistor. The non-inverting input (pin 3) receives a programmable threshold voltage from a Microchip MCP4725A1T-E/CH 12-bit I²C DAC (SOT-23-6, \$1.27), filtered by a 2.2 k Ω + 4.7 nF RC network ($\tau \approx 10$ μ s) to suppress switching transients. The MCP4725 is controlled over I²C (I2C1, GP2/GP3, 10 kHz) and is programmed on every boot to set the

threshold at approximately 0.8 V, overriding the EEPROM default of 1.64 V which provides insufficient margin for the TIA's output swing. The shutdown pin (pin 6) of the TLV3501 is tied to ground to enable the comparator, as the TLV3501 uses active-high shutdown logic: a high level on the SHDN pin places the device in a low-power state with a high-impedance output.

- 4) **Digital output**. The comparator's push-pull output drives GP27 on the Pico 2 through a 33 Ω series resistor. The signal polarity is inverted relative to conventional UART: the line idles low (no light, TIA output near 0 V, comparator output high is inverted by the optical path) and a start bit is indicated by a high-to-low transition at GP27.

2) *Receiver Power and Robotic Integration*: The receiver PCB is designed for untethered deployment on a Pololu 3pi+ mobile robot platform. A 22-pin (2 $\times$ 11, 2.54 mm pitch) robot header and a separate 14-pin (2 $\times$ 7) expansion connector carry power and I/O signals between the PCB and the robot mainboard, allowing the receiver to draw regulated power from or share GPIO with the robot controller. Onboard power management consists of a Texas Instruments TPS63031DSKR synchronous buck-boost converter (3.3 V, 900 mA) that accepts input from either a USB-C port or a single-cell lithium-polymer battery connected via a JST-PH 2-pin connector. A Texas Instruments BQ24074RGTR single-cell LiPo charge management IC (16-QFN) with programmable charge current (set by a 1.78 k Ω resistor to approximately 500 mA) enables field recharging via USB-C without removing the battery, supporting continuous mobile operation. This architecture allows the receiver to operate autonomously aboard the robot, granting or revoking the robot's operational authority based solely on whether it remains within the optical transmission cone of the sender.

3) *PIO-Based Reception*: A custom PIO state machine implements 8N1 UART reception with inverted polarity to match the analog front-end's signal convention. The state machine waits for a rising edge (start bit in inverted polarity), delays to the center of the first data bit, then samples 8 bits at 8 PIO cycles per bit. Data is shifted right into the input shift register and auto-pushed at 8 bits, placing the received byte in bits [31:24] of the 32-bit FIFO word. The firmware extracts and inverts the byte:

$$\text{byte} = \sim(\text{word} \gg 24) \quad (2)$$

where the bitwise complement corrects for the optical inversion of data bits. The PIO clock divider is set identically to the transmitter: at 150 MHz system clock (RP2350 default), $\text{div} = 150,000,000 / (1,000,000 \times 8) = 18.75$.

4) *Frame Synchronization and Decryption*: A state machine in firmware implements preamble detection by sequentially matching the four synchronization bytes (0xAB, 0xCD, 0xEF, 0x12). Any byte mismatch during the preamble sequence resets the detector to its initial hunting state. Upon successful preamble detection, subsequent bytes are accumulated into

a payload buffer until a terminator or maximum length is reached, at which point the frame is passed to AES-128-GCM decryption and tag verification.

A 64-entry circular nonce window provides replay attack prevention without requiring synchronized clocks: each received nonce is checked against the window, and duplicate nonces are rejected before decryption is attempted.

C. Key Provisioning

Session keys are provisioned through the SST (Secure Swarm Toolkit) IoTAuth framework, which implements a centralized key distribution service with per-device authentication.

1) *IoTAuth Integration*: A Linux-based receiver application (`keys_receiver`) connects to the IoTAuth authentication server over TLS, authenticates using entity credentials (X.509 certificate and private key), and requests a session key for the designated communication group. The server returns a session key structure containing an 8-byte key identifier, a 16-byte cipher key, validity parameters, and a cipher mode indicator.

2) *Key Delivery to Sender*: The provisioned session key is delivered to the Pico sender over a dedicated UART channel (UART1, GP4/GP5, 1 Mbps). The delivery protocol uses the same 2-byte preamble (`0xAB 0xCD`) followed by the 16-byte key. Upon receipt, the Pico stores the key in the next available flash slot and updates the index sector.

An HMAC-SHA256 challenge-response protocol authenticates the key exchange:

- 1) The sender generates a 32-byte random challenge and transmits it to the provisioning host.
- 2) The host computes $\text{HMAC-SHA256}(K_{\text{session}}, \text{challenge})$ and returns the 32-byte response.
- 3) The sender independently computes the same HMAC using its copy of the session key and compares the result. A match confirms that both parties hold the same key.

3) *Key Delivery to Receiver*: Unlike the sender, the receiver in the evaluated two-microcontroller configuration does not itself authenticate to the IoTAuth server or hold network credentials — the Pico 2 H used in this prototype has no wireless interface, and `receiver_pico/src/main.c` implements no TLS client. Instead, the session key reaches the receiver over its USB serial console: the sender prints its active session key in hex after receiving it from the provisioning host, and an operator pastes this value into the receiver's `key <hex>` console command, which accepts the identical hex format and loads it for on-device AES-128-GCM decryption.

This is a manual, operator-mediated step in the current prototype, not an independently authenticated network exchange — the receiver's copy of the key is only as trustworthy as the local USB connection used to enter it, and it is not corroborated by any second, independent channel the way the sender's HMAC-SHA256 challenge-response (Section III-C) corroborates its own. Automating this — for example, having the receiver retrieve its key from IoTAuth via a networked host companion once the receiver's optical key identifier is decoded, so both devices' keys are established over two

independently authenticated channels rather than one being copied by hand — is identified as future work (Section VII).

4) *Key Rotation*: The dual-slot flash architecture enables zero-downtime key rotation. A new key is written to the inactive slot while the active slot continues to serve encryption operations. The `use slot` command atomically switches the active slot by updating the index sector. The previous key remains available as a fallback until explicitly erased with `clear slot`, enabling graceful rollback in the event of a provisioning failure.

D. Presence Enforcement

The physical properties of the optical channel directly enforce presence-based authorization. Because visible and near-infrared light does not penetrate opaque barriers, the receiver must maintain continuous line-of-sight to the transmitter to receive the modulated signal. Any interruption of the optical path — whether by physical obstruction, misalignment, or movement out of the illumination cone — immediately halts the flow of authenticated frames.

The system defines a configurable token validity window Δ . The receiver considers its authorization valid only while it has received at least one successfully authenticated frame within the most recent Δ interval. If no valid frame arrives within Δ , authorization is revoked and the receiver ceases to act on previously received commands. This transforms the physical geometry of the optical link into a continuously enforced security boundary: authorization persists only as long as the device remains in the light.

IV. THREAT MODEL AND SECURITY GOALS

This section defines the system model, the capabilities attributed to the adversary, the trust assumptions under which the system operates, and the security goals that the protocol is designed to achieve. We conclude with an explicit enumeration of non-goals — properties that the system does not claim to provide — to bound the scope of the security analysis and prevent misinterpretation of the system's guarantees.

A. System Model

The system consists of three classes of participants:

- 1) **Optical beacon (sender)**. A microcontroller-based transmitter that emits short-lived cryptographic material — encrypted and authenticated frames — over a modulated optical channel. The beacon is assumed to be physically secured and under the control of the system administrator. It possesses a valid session key and continuously transmits authenticated frames at a rate sufficient to refresh the receiver's authorization within the validity window Δ .
- 2) **Client device (receiver)**. A microcontroller-based receiver equipped with a photodiode and analog front-end that demodulates the optical signal, verifies the cryptographic authentication of received frames, and maintains a time-decaying authorization state. The receiver considers itself authorized only while it has successfully

verified at least one authenticated frame within the most recent interval of length Δ . Upon expiration of this window without a valid frame, authorization is revoked.

- 3) **Key provisioning service (verifier).** A network-accessible authentication server (IoTAuth) that issues session keys to authorized entities through a TLS-protected channel with mutual authentication via X.509 certificates. The provisioning service is the root of trust for key material and is assumed to be secure.

Communication between the sender and receiver occurs exclusively over the optical channel. Communication between the receiver and the provisioning service occurs over a conventional network channel (TCP/TLS). The sender receives its session key from the provisioning service via a serial (UART) connection to a Linux host that acts as an intermediary.

B. Adversary Model

We consider a computationally bounded adversary $\mathcal{A}$ whose goal is to cause the receiver to accept authorization without maintaining legitimate physical presence within the optical transmission cone. The adversary is attributed the following capabilities:

- 1) *Network Control:* $\mathcal{A}$ has full control over the network path between the receiver and the provisioning service. Specifically, $\mathcal{A}$ can eavesdrop on, replay, delay, drop, reorder, and inject packets on any RF-based or wired network link. This is the standard Dolev-Yao network adversary model. The optical channel between the sender and receiver is not subject to this capability — $\mathcal{A}$ cannot inject packets into or modify packets on the optical link without physical access to the transmission cone.

- 2) *Optical Observation:* $\mathcal{A}$ can position commodity optical sensors (cameras, photodiodes) within the physical space to passively observe the modulated optical signal. This captures the scenario in which the optical channel is not physically enclosed — for example, an outdoor deployment where the LED emission is visible from a distance. Passive observation grants $\mathcal{A}$ access to the transmitted ciphertext, authentication tags, and nonces, but not to the plaintext or key material (which are protected by AES-128-GCM).

- 3) *Relay:* $\mathcal{A}$ can capture the optical signal at the legitimate transmission site using a photodiode, convert it to an electrical signal, transport it over an arbitrary medium (fiber, coaxial cable, RF link), and re-emit it from a rogue light source at a remote location. The relay introduces a minimum latency consisting of the photodetection time, analog-to-digital conversion, transport delay, digital-to-analog conversion, and re-emission time. This latency is bounded below by the physical propagation delay of the relay medium and the processing latency of the conversion hardware, and is denoted δ_{relay} .

- 4) *Optical Injection:* $\mathcal{A}$ can position a rogue light source within the receiver's field of view and attempt to transmit crafted optical frames. However, without knowledge of the current session key, $\mathcal{A}$ cannot produce frames that pass AES-128-GCM tag verification. Injection of previously captured

frames constitutes a replay attack, addressed by the nonce window mechanism.

- 5) *Denial of Service:* $\mathcal{A}$ can physically obstruct the optical path between sender and receiver (shadowing), overwhelm the photodiode with ambient light to saturate the analog front-end, or jam the RF network link to the provisioning service. We do not claim to prevent denial of service — the system is designed to *fail closed*: denial of the optical signal results in authorization revocation, not authorization persistence.

C. Trust Assumptions

The security analysis is conducted under the following assumptions:

- 1) **Trusted provisioning service.** The IoTAuth server and its long-term cryptographic keys (X.509 certificates, private keys) are not compromised. The server correctly authenticates entities and distributes session keys only to authorized participants.
- 2) **Trusted sender hardware.** The optical beacon (Pico sender) is physically secured against tampering. An adversary who gains physical access to the sender can extract the session key from flash memory, which is equivalent to full compromise and outside the scope of the protocol guarantees.
- 3) **Standard cryptographic assumptions.** AES-128-GCM provides IND-CPA confidentiality and INT-CTXT integrity under the assumption that the key is secret and nonces are never reused. HMAC-SHA256 is a secure message authentication code under the assumption that the key is secret. SHA-256 is collision-resistant. CTR_DRBG seeded with sufficient entropy produces computationally indistinguishable pseudorandom output.
- 4) **Bounded clock drift.** The sender and receiver maintain sufficiently accurate local clocks (or frame counters) to support the token validity window Δ . The RP2040 and RP2350 system clocks, while not synchronized to an external time source, provide millisecond-resolution timing adequate for Δ values on the order of hundreds of milliseconds to seconds.
- 5) **No full client compromise.** The receiver device has not been compromised by malware that extracts cryptographic keys or manipulates the authorization logic. Side-channel attacks on the receiver's AES implementation are not considered. A receiver that has been fully compromised can trivially bypass any software-enforced authorization policy, regardless of the protocol design.

D. Security Goals

The primary objective is *presence-based authorization*: a device should remain authorized if and only if it can demonstrate continuous, fresh physical presence within the optical transmission cone within a bounded time window Δ . We decompose this objective into four concrete security goals.

- 1) *G1 — Freshness and Expiration:* **Definition.** Authorization depends on presence material (authenticated optical frames) that expires automatically after a configurable interval

Δ . A receiver that has not successfully verified a fresh authenticated frame within the most recent Δ interval shall consider its authorization revoked, regardless of how many valid frames it received previously.

Mechanism. The receiver maintains a timestamp t_{last} recording the time at which the most recent frame passed GCM tag verification and nonce validation. At any decision point, the receiver evaluates:

$$\text{authorized}(t) = \begin{cases} \text{true} & \text{if } t - t_{\text{last}} \leq \Delta \\ \text{false} & \text{otherwise} \end{cases} \quad (3)$$

The sender transmits authenticated frames at a rate $r > 1/\Delta$, ensuring that a legitimately positioned receiver receives sufficient refresh material to maintain continuous authorization.

Rationale. Freshness prevents an adversary from capturing a valid frame and presenting it at an arbitrarily later time to claim presence. Without freshness enforcement, a single valid reception would grant indefinite authorization, defeating the purpose of continuous presence verification.

2) *G2 — Replay Resistance:* **Definition.** A previously observed authenticated frame shall not be accepted as valid upon re-presentation to the receiver. Specifically, if a frame with nonce n was accepted at time t_1 , any subsequent frame bearing the same nonce n shall be rejected for as long as n remains in the receiver’s replay window W (Equation (4)); window capacity bounds this guarantee, as characterized empirically in Section V-E.

Mechanism. The receiver maintains a circular buffer of the 64 most recently accepted nonces. Before decryption, each incoming frame’s nonce is checked against this window:

$$\text{accept}(n) = \begin{cases} \text{true} & \text{if } n \notin W \\ \text{false} & \text{if } n \in W \end{cases} \quad (4)$$

where W is the set of nonces currently in the replay window. Upon acceptance, n is added to W , evicting the oldest entry if the window is full. Insertion is gated on successful GCM authentication rather than on frame-format validity alone: an earlier implementation added n to W once CRC and message-type checks passed, before decryption was attempted, which would have let an attacker without the session key force eviction of a genuinely captured nonce using unauthenticated, syntactically well-formed frames. This was corrected during evaluation so that only frames passing full GCM verification are recorded in W , ensuring eviction requires possession of the session key.

The nonce itself is constructed as the concatenation of an 8-byte random boot salt and a 4-byte monotonically increasing counter. The boot salt ensures that nonces from different boot sessions are distinct with overwhelming probability, and the counter ensures that nonces within a single boot session are strictly unique. Counter exhaustion (2^{32} messages) triggers an immediate device reboot, regenerating the boot salt and resetting the counter.

Rationale. Replay resistance is essential because the optical channel is observable: an adversary positioned within line

of sight of the sender can capture valid frames. Without nonce-based replay detection, the adversary could re-transmit captured frames from a rogue light source to fraudulently claim presence.

3) *G3 — Relay-Bounded Authorization (not achieved):*

Definition. A relay attack — in which the adversary captures the optical signal at the legitimate location and re-emits it at a remote location in real time — should not grant the remote receiver authorization, or should at minimum incur a detectable, bounded timing penalty proportional to the relay’s introduced latency δ_{relay} .

Status: not achieved by the current implementation. We state this explicitly rather than let it be inferred, because it is easy to conflate with G2. The freshness window Δ (G1) bounds how long a *captured-and-later-resent* frame remains useful, and the nonce window (G2) rejects a *byte-identical resend* outright. Neither mechanism examines *when* a frame arrived relative to when it was sent, only whether its nonce is fresh and unseen. A live relay that forwards genuinely fresh frames — never storing and replaying stale bytes, simply passing each frame through with added latency δ_{relay} — produces frames that are, from the receiver’s point of view, indistinguishable from frames arriving directly: the nonce has never been seen before (G2 passes), the GCM tag is valid because the ciphertext is untouched (confidentiality/integrity passes), and t_{last} is continuously refreshed because relayed frames keep arriving within Δ (G1 passes). We verified this directly against the receiver implementation: the LiFi data-frame path (guarded by the nonce window in `process_complete_frame()`, `receiver_pico/src/main.c`) checks only CRC validity and byte-exact nonce identity — there is no timestamp field, round-trip bound, or any other timing-derived check on the data path. Consequently, Δ does not bound relay latency at all; it bounds only the residual validity of a captured, no-longer-live frame, which is the mechanism underlying G1/G2, not G3.

What would be required. Relay-boundedness requires binding authorization to a measured round-trip time, not merely to nonce freshness — e.g., a distance-bounding challenge-response (Brands–Chaum style) in which the receiver issues a random nonce and the sender must respond within a tightly bounded window, with any added relay latency δ_{relay} causing the response to arrive too late to verify. This is not implemented in the current prototype; see Section VI and Section VII.

Rationale. Relay attacks are the most realistic threat against an optical presence system, since unlike RF, optical relay requires physical conversion (light to electrical to light) that introduces measurable delay. We report G3 as an explicit, named limitation rather than an inferred one: a system that is precise about what it does and does not defend against is more defensible at review than one that leaves the gap to be discovered.

4) *G4 — Revocation on Interruption:* **Definition.** If the optical path between the sender and receiver is interrupted — by physical obstruction, device movement, misalignment,

or removal — the receiver’s authorization shall be revoked within at most Δ time units.

Mechanism. This property follows directly from G1. When the optical path is interrupted, no new authenticated frames reach the receiver. The most recent valid frame’s timestamp t_{last} becomes stale, and within Δ seconds the freshness condition in Equation (3) evaluates to false. No explicit revocation message is required — the absence of the optical signal is itself the revocation event.

Rationale. Revocation on interruption is the defining property that distinguishes presence-based authorization from credential-based authorization. In a conventional system, a device that has authenticated retains its authorization until an explicit revocation is issued by the server or the credential expires. In the optical presence model, authorization is an ongoing physical condition, not a stored state. The device is authorized because it is here, now, in the light — and ceases to be authorized the moment it is not.

This property provides defense-in-depth against device theft: an attacker who physically removes an authorized device from the optical transmission zone has at most Δ seconds of residual authorization before the device self-revokes, without any network-based revocation infrastructure.

E. Non-Goals

The following properties are explicitly outside the scope of this system’s security claims:

- 1) **Indoor localization.** The system does not provide precise geometric positioning of the receiver. It asserts that the receiver is within the optical transmission cone of a specific sender, but does not compute coordinates, floor assignments, or room-level granularity beyond what is implied by the sender’s physical placement.
- 2) **Denial-of-service prevention.** An adversary who can physically obstruct the optical path or saturate the photodiode with ambient light can deny authorization to a legitimate receiver. The system is designed to fail closed: denial results in revocation (a safe state), not in false authorization (an unsafe state). This is a conscious design choice — availability is sacrificed in favor of safety.
- 3) **Full device compromise.** If the receiver’s firmware is replaced, its RAM is read by a debugger, or its flash is extracted, the adversary obtains the session key and can decrypt captured frames. The system does not incorporate hardware-based key protection (e.g., a Trusted Platform Module) in the current implementation, though the architecture is designed to accommodate such an extension. The use of `secure_zero()` for RAM clearing and SHA-256 integrity hashing for flash storage represents a best-effort mitigation within the constraints of a microcontroller platform without hardware key isolation.
- 4) **Covert channel resistance.** The optical transmission is visible to any observer within line of sight (for visible-light implementations) or detectable with appropriate

sensors (for near-infrared implementations). The system does not claim to hide the existence of the communication channel. Confidentiality of the *content* is provided by AES-128-GCM; concealment of the *channel* is not.

- 5) **Multi-sender disambiguation.** The current implementation assumes a single sender per receiver. Environments with multiple overlapping optical transmission cones would require sender identification (e.g., via key identifiers or sender-specific preambles) to prevent a receiver from accepting frames from an unintended source. This extension is architecturally supported by the key identifier field in the flash block structure but is not implemented or evaluated in this work.

F. Summary of Security Properties

Table I summarizes the mapping between security goals and the mechanisms that enforce them.

TABLE I: Security Goals and Enforcement Mechanisms

Goal	Property	Mechanism
G1	Freshness / Expiration	Token window Δ
G2	Replay Resistance	64-nonce sliding window
G3	Relay-Bounded Auth	Not achieved — no timing check on data path
G4	Revocation on Interruption	Absence of signal = revocation
—	Confidentiality	AES-128-GCM
—	Integrity / Authenticity	GCM 16-byte auth tag
—	Key Authenticity	HMAC-SHA256 challenge-response
—	Nonce Uniqueness	Boot salt + atomic counter
—	Key Persistence	Dual-slot A/B with SHA-256
—	Key Confidentiality (RAM)	<code>secure_zero()</code> volatile erase

V. EVALUATION

This section presents the experimental methodology and results. Detailed measurements of communication performance, analog front-end characterization, security validation, and presence enforcement are reported.

A. Experimental Setup

The testbed consists of the following hardware.¹

The sender Pico is powered by a 12 V DC bench supply via screw terminal; the PTN78000WAH module on the sender PCB steps this down to 5 V for the RP2040 VSYS rail, while the four LED channels are switched directly from the 12 V supply through the TC4420COA–SIR800DP MOSFET stage. The receiver Pico 2 is powered either via USB-C or from

¹All firmware, build scripts, and configuration files are open source and available at <https://github.com/asu-kim/lifi-auth>.

TABLE II: Verified Bill of Materials (DigiKey Invoices #120241715, #121892487)

Component	Part Number	Cost
<i>Sender Subsystem</i>		
Sender MCU	Pico H, RP2040 (SC0917)	\$5.00
Gate Driver $\times 4$	TC4420COA (Microchip)	\$1.80 ea.
MOSFET $\times 4$	SIR800DP-T1-GE3 (Vishay)	\$0.88 ea.
DC-DC Module	PTN78000WAH (TI, 12 V $\rightarrow$ 5 V)	\$24.58
LED Array	SFH 4715A-CBDB (OSRAM)	\$2.50
<i>Receiver Subsystem</i>		
Receiver MCU	Pico 2 H, RP2350 (SC1632)	\$6.00
TIA	OPA381AIDGKT (TI, 8-VSSOP)	\$2.93
Photodiode	SFH 2400-Z (OSRAM, 900 nm)	\$0.79
Comparator	TLV3501AIDBVR (TI, SOT-23-6)	\$2.64
DAC	MCP4725A1T-E/CH (Microchip)	\$1.27
LiPo Charger	BQ24074RGTR (TI, 16-QFN)	\$2.50
Buck-Boost Reg.	TPS63031DSKR (TI, 3.3 V)	\$2.14
<i>Shared</i>		
Passives & connectors	R, C, fuses, JST, Würth	$\sim$ \$15
Custom PCBs ($\times 2$)	2-layer, fabricated externally	$\sim$ \$10
Total		$\sim$\$82

a single-cell LiPo battery through the BQ24074 charger and TPS63031 buck-boost on the receiver PCB. All firmware is written in C, compiled with the Pico SDK and ARM GCC toolchain. The IoTAuth key-provisioning service runs on a Raspberry Pi 4 under Linux; this host is used only at session-key setup time (Section III-C) and is not part of the runtime data path between sender and receiver. Serial monitoring and control of the receiver are provided by the `rx_monitor.py` utility.

For the freshness, revocation-latency, and replay-boundary measurements reported in Sections V-F and V-E, the receiver-side protocol logic under test — CRC validation, nonce-window replay checking, and AES-128-GCM decryption — runs directly on the receiver firmware (`receiver_pico/src/main.c`) deployed in the evaluated two-microcontroller architecture. At the time these measurements were collected, the Δ -based freshness/revocation decision itself (Section V-F) was computed by an external monitoring script observing structured per-frame event logs over USB serial, mirroring the decision logic rather than reading it from an on-device state flag. This decision logic has since been ported directly into the receiver firmware as well (`presence_check_decay()`), making revocation a purely on-device determination; Section V-F reports a third measurement batch collected directly from this on-device implementation, confirming the earlier externally-measured numbers.

B. Hardware Prototype

The system was realized on two custom printed circuit boards designed in KiCad and fabricated as 2-layer boards, with all active components procured through DigiKey Electronics (invoices #120241715 and #121892487).

Receiver PCB. The receiver analog front-end is implemented on a compact PCB designed for direct integration with a Pololu 3pi+ mobile robot platform via a 22-pin (2×11 , 2.54 mm) robot header and a 14-pin expansion connector, enabling untethered robotic deployment. The board hosts the OPA381AIDGKT transimpedance amplifier (8-VSSOP) alongside an OSRAM SFH 2400-Z silicon PIN photodiode, a TI TLV3501AIDBVR high-speed comparator (SOT-23-6), and a Microchip MCP4725A1T-E/CH 12-bit I²C DAC for programmable threshold control. Onboard power management consists of a TI TPS63031DSKR synchronous buck-boost converter providing 3.3 V to the RP2350 logic supply from either the USB-C input or a lithium-polymer battery via JST-PH connector, and a TI BQ24074RGTR single-cell LiPo charger that enables field recharging without board removal. Test points are provided for VSYS, VOUT, and ground. Figs. 1 and 2 show the 3D KiCad renders with all components labeled.

Sender PCB. The sender board drives four independent LED channels from a 12 V DC supply through a screw-terminal power connector with TVS and fuse protection. Each channel consists of a TC4420COA low-side gate driver (4.5 A peak) followed by a Vishay SIR800DP-T1-GE3 N-channel MOSFET (40 V, 80 A, PPAK) as the switching element. A Texas Instruments PTN78000WAH wide-input DC-DC module provides a regulated 5 V supply to the RP2040 VSYS pin. The OSRAM SFH 4715A-CBDB four-channel LED array connects via two four-position Würth Elektronik screw-terminal blocks (anode and cathode).

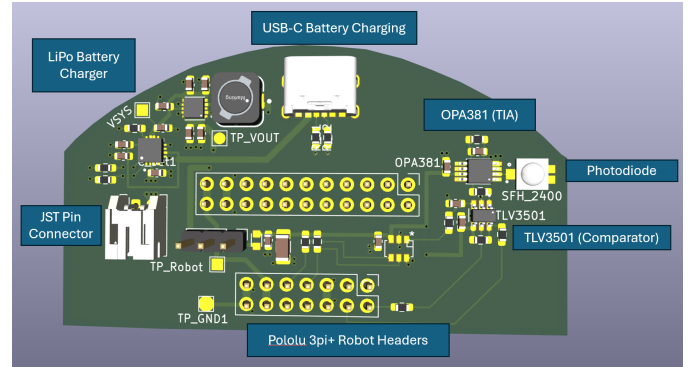


Fig. 1: (a) Receiver analog front-end PCB: OPA381AIDGKT TIA, SFH 2400-Z photodiode, TLV3501AIDBVR comparator, MCP4725 DAC, TPS63031 3.3 V regulator, BQ24074 LiPo charger, Pololu 3pi+ robot headers, and USB-C charging port.

C. Communication Performance

Bit-error-rate testing was conducted at a separation distance of approximately 15 cm between the sender LED array and the receiver photodiode, using the white LED channel with

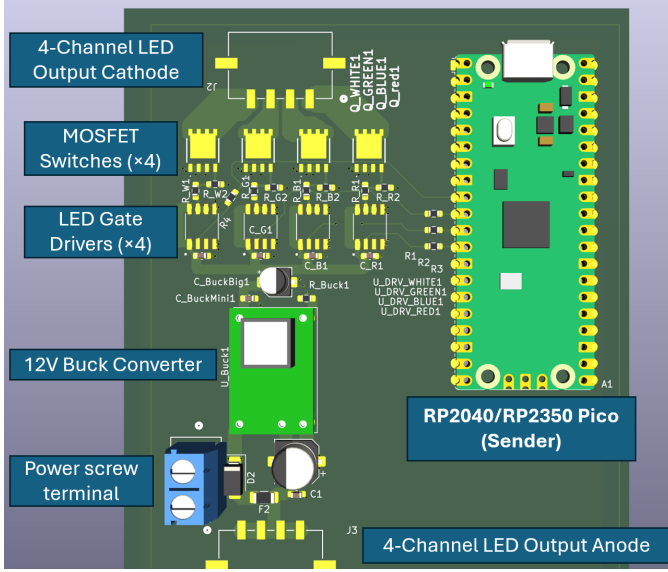


Fig. 2: (b) Sender LED driver PCB: RP2040/RP2350 Pico, TC4420COA gate drivers ($\times 4$), SIR800DP-T1-GE3 MOSFETs ($\times 4$), PTN78000WAH 12 V $\rightarrow$ 5 V module, and 4-channel LED terminal blocks.

a 50-packet sample per baud rate. Testing was performed under indoor ambient lighting without shielding. The PIO state machine on the RP2040 was configured for 1 Mbps (clock divider 15.625 at 125 MHz system clock), and baud rate was swept by adjusting the clock divider.

With $R_f = 470\text{ k}\Omega$ (2.0 V output swing), the system achieved 100% frame success at baud rates up to 300 kbaud, with hard failure onset above 350 kbaud. With $R_f = 100\text{ k}\Omega$ (400 mV output swing), reliable reception was achieved at up to 250 kbaud, with complete failure above 400 kbaud. Notably, the higher-gain 470 k Ω configuration outperformed the lower-gain 100 k Ω configuration at this distance, indicating that SNR margin from the larger output swing was the dominant factor at close range. At longer distances, the bandwidth advantage of the 100 k Ω configuration is expected to dominate as photocurrent decreases and the voltage swing falls below the comparator’s noise floor. Extended range and multi-distance characterization are planned for future work.

D. Analog Front-End Characterization

TABLE III: TIA Feedback Component Tuning

R_f	C_f	BW (kHz)	Max Baud (meas.)	Swing
470 k Ω	5 pF	68	300,000	$\sim 2.0\text{ V}$
100 k Ω	5 pF	318	250,000	$\sim 400\text{ mV}$
100 k Ω	1 pF	1,590	TBD	$\sim 400\text{ mV}$
47 k Ω	1 pF	3,386	TBD	$\sim 200\text{ mV}$

The first two rows of Table III have been experimentally validated. The 470 k Ω / 5 pF configuration achieved reliable reception at up to 300 kbaud at 15 cm; the 100 k Ω / 5 pF

configuration achieved up to 250 kbaud at the same distance. The lower-resistance configurations (100 k Ω / 1 pF and 47 k Ω / 1 pF) are planned for evaluation in future work targeting data rates above 1 Mbps.

E. Security Validation

Authentication is enforced per-frame by the mbedTLS AES-128-GCM implementation. Each received frame is passed to `mbedtls_gcm_auth_decrypt()`, which verifies the 16-byte GCM authentication tag before returning plaintext. Any frame with a corrupted, truncated, or forged tag causes mbedTLS to return `MBEDTLS_ERR_GCM_AUTH_FAILED`; the frame is discarded and the authorization timestamp is not updated. No partial plaintext is released to the application layer prior to successful tag verification — a property guaranteed by the GCM-authenticated decryption interface.

Replay protection is enforced by the 64-entry nonce sliding window (`NONCE_HISTORY_SIZE`). Each incoming frame’s 12-byte nonce is checked against the window before decryption is attempted. A frame bearing any nonce already present in the window is rejected without invoking the GCM primitive. Nonce uniqueness within a boot session is guaranteed by the monotonically increasing 32-bit counter field; uniqueness across reboots is ensured with overwhelming probability by the 8-byte random boot salt generated from the RP2040 hardware ring-oscillator entropy source via `CTR_DRBG` at startup. Counter exhaustion (2^{32} messages) triggers a device reboot to regenerate the salt, preventing nonce reuse.

Replay rejection test. Using an automated harness (`thesis_eval/replay_test.py`) that captures one valid encrypted frame’s raw bytes (type, nonce, ciphertext, and GCM tag) directly off the receiver’s decoded output and re-injects the identical bytes back into the receiver’s input, we ran 25 independent trials. In all 25/25 trials the replayed frame was rejected immediately, with the nonce-window check (`replay=YES`) firing before decryption was attempted, confirming G2 as designed with no observed exceptions.

Replay window boundary test. The same harness then reduced the nonce window’s capacity to 2 entries at runtime, allowed 2 further legitimate frames to be received (evicting the captured frame’s nonce from the window), and re-injected the identical captured frame a second time, across the same 25 trials. In all 25/25 trials the replayed frame was accepted and successfully decrypted, with no exceptions. This reproduces a genuine, consistently reproducible boundary limitation of the sliding-window design: replay protection is bounded by window capacity, not permanent — once a nonce has aged out of the window (64 entries in the production configuration, versus the 2-entry setting used here to make the boundary condition observable within a short test), an identical previously-accepted frame becomes acceptable again. In practice, exhausting the production 64-slot window before an adversary reuses a captured frame requires 64 further legitimate frames to be exchanged, which at the sender’s minimum authenticated-frame rate ($1/\Delta$, see Section V-F) bounds how long a captured frame remains a live replay threat

— but the limitation is real and is not eliminated by window size alone. This distinction is recorded here explicitly rather than left for a reviewer to discover.

Quantitative measurements of tag verification latency and tampered-frame rejection rates across a larger packet sample remain future work.

F. Presence Enforcement

Authorization revocation upon optical interruption follows directly from the freshness mechanism defined in Equation (3). When the optical path is broken, no new authenticated frames reach the receiver, and the authorization timestamp t_{last} becomes stale. Within at most Δ time units, the freshness condition evaluates to false and the receiver revokes authorization without any explicit network-level revocation message.

Occlusion (shadowing) test. The production configuration uses $\Delta = 15\text{ s}$ (`LIVENESS_WINDOW_MS` in the receiver firmware’s `presence_check_decay()`; mirrored by an external monitoring script at the time these measurements were collected, see Section V-A). To exercise this experimentally, the sender firmware was extended with an idle-time heartbeat — a small authenticated frame sent automatically every 2.5 s using the existing `encrypt/frame/send` path — so that continuous traffic exists to interrupt. With the link at steady-state (`verified: true`), the optical path was physically occluded at a marked $t = 0$; the time to the corresponding revocation event was logged, the path was then unblocked, and the time back to re-verification was logged. This was repeated across three batches: 21 trials polling receiver state at 5.0 s intervals (the external monitoring script’s production polling cadence), 20 trials at 0.2 s intervals (to isolate polling-granularity jitter from the mechanism’s intrinsic latency), and, following the on-device port of the revocation decision (`presence_check_decay()`), 25 trials reading the receiver’s own [PRESENCE] state transitions directly, with no external polling involved at all.

TABLE IV: Revocation and Re-verification Latency ($\Delta = 15\text{ s}$)

Condition	Time-to-revoke	Time-to-reverify
As-deployed (5 s poll), $n=21$	$17.27\text{ s} \pm 1.25\text{ s}$	$1.43\text{ s} \pm 0.69\text{ s}$
Fine-grained (0.2 s poll), $n=20$	$15.11\text{ s} \pm 0.06\text{ s}$	$1.30\text{ s} \pm 0.65\text{ s}$
On-device decision, $n=25$	$15.001\text{ s} \pm 0.000\text{ s}$	$1.33\text{ s} \pm 0.62\text{ s}$

At the production polling cadence, measured time-to-revoke was bimodal (clustering near 15.7 s and 18.2 s), an artifact of the 5 s poll interval aliasing against the underlying revocation event rather than a property of the freshness mechanism itself. At the fine-grained polling cadence, time-to-revoke collapsed to a tight cluster at $15.11\text{ s} \pm 0.06\text{ s}$ — essentially exactly Δ plus a fixed $\approx 0.11\text{ s}$ processing overhead — confirming that the mechanism enforces its configured bound precisely, and that the additional latency and variance observed in the as-deployed measurement is attributable to the external monitoring script’s poll granularity, not the underlying protocol.

Reading the revocation decision directly from the receiver’s own [PRESENCE] transitions confirms this without relying on any external observation cadence at all: time-to-revoke collapsed further, to $15.001\text{ s} \pm 0.000\text{ s}$ across all 25 trials — every trial hit the same value because the on-device check runs every main-loop iteration, so revocation fires the instant the timer crosses Δ , independent of how long the occlusion continues afterward. This closes the on-device re-confirmation previously identified as pending work (Section VI-D) and is the strongest available evidence that Δ is enforced exactly, not just approximately. Time-to-reverify was consistent across all three batches ($\approx 1.3\text{--}1.4\text{ s}$) and is bounded above by the 2.5 s heartbeat interval, as expected.

Δ sensitivity to benign traffic. To assess whether $\Delta = 15\text{ s}$ is justified rather than arbitrary, we logged inter-frame gaps over a 40-minute benign session (960 frames, 959 gaps) and computed, for candidate $\Delta \in \{3, 5, 10, 15, 20, 30\}\text{ s}$, the fraction of observed gaps that would have exceeded each candidate (a false-revoke event under benign conditions). With heartbeat-only traffic, gaps clustered tightly at 2.409–2.591 s (98% within $\pm 20\text{ ms}$ of the 2.5 s heartbeat interval), yielding a measured false-revoke rate of 0.0% at every candidate Δ tested, including the smallest. This result is degenerate rather than informative: a single mechanically regular heartbeat does not exhibit the gap variability that real, possibly degraded, optical conditions would produce, so it cannot by itself justify a specific Δ against false-revoke risk. We therefore report the finding narrowly — $\Delta = 15\text{ s}$ carries zero measured false-revoke cost against heartbeat-only traffic — and identify a full parametric justification of Δ , characterizing gap variability under real degraded-signal conditions (partial occlusion, marginal alignment, ambient light transients), as future work.

At a reliable frame rate of up to 300 kbaud with standard message sizes, the sender is capable of delivering many authenticated frames per Δ interval, well in excess of the minimum rate $r > 1/\Delta$ required to maintain continuous authorization for a legitimately positioned receiver.

VI. DISCUSSION

A. The Bandwidth-Range Tradeoff

The analog front-end characterization reveals a fundamental tradeoff between communication bandwidth and operational range. The TIA feedback resistor R_f simultaneously controls the gain (and therefore the signal swing available to the comparator) and the bandwidth (and therefore the maximum achievable data rate). Measured results show that at close range (15 cm), reducing R_f from 470 k Ω to 100 k Ω did not improve maximum reliable baud rate — the higher-gain 470 k Ω configuration achieved 300 kbaud versus 250 kbaud for the 100 k Ω configuration. This result indicates that at close range, the SNR margin from the larger output swing (2.0 V vs. 400 mV) is the dominant factor, offsetting the bandwidth advantage of the lower-resistance configuration. At longer operational distances, the balance is expected to shift: as photocurrent decreases, the 2.0 V swing of the 470 k Ω configuration will degrade first, and the higher bandwidth of

the 100k Ω configuration will dominate. This reduced swing directly limits the maximum distance at which the comparator can reliably distinguish signal from noise, particularly under ambient light interference.

This tradeoff is not unique to our system — it is inherent to any transimpedance-based optical receiver — but it has specific implications for presence-based authorization. A system deployed in a large room with ceiling-mounted LEDs would require higher TIA gain (and therefore lower bandwidth) than a system deployed at close range on a desktop. The programmable DAC threshold partially mitigates this by allowing the comparator decision point to track the reduced swing, but the fundamental sensitivity limit imposed by the photodiode’s noise floor and the comparator’s 6 mV hysteresis remains.

Future implementations could address this tradeoff through a dedicated high-bandwidth transimpedance amplifier IC (replacing the general-purpose operational amplifier), a second-stage voltage amplifier to recover signal amplitude after a low-gain TIA, or optical concentrators (lenses, compound parabolic concentrators) on the receiver to increase the effective collection area without modifying the electronics.

B. Relay Attack Resilience — a Named Limitation

As established in Section IV (G3), the current implementation does *not* bound relay attacks. The Δ -bounded freshness mechanism (G1) and the nonce sliding window (G2) together prevent an adversary from presenting a *captured, no-longer-live* frame after the fact, but neither examines transit time, so a *live* relay that forwards genuinely fresh frames in real time — introducing latency δ_{relay} but never storing and resending stale bytes — passes every check the receiver performs. This distinction matters because it is easy to mistake G1’s expiration window for a relay bound; it is not, since a continuously operating relay keeps t_{last} refreshed indefinitely.

Closing this gap would require binding authorization to a measured round-trip time rather than to nonce freshness alone: a distance-bounding challenge-response (Brands–Chaum style), in which the receiver periodically issues a random nonce and the sender must respond within a tightly bounded window, such that any relay-introduced latency δ_{relay} becomes directly detectable. Since the optical channel operates at the speed of light (negligible propagation delay at room scale) and the existing bidirectional UART link between sender and receiver already provides the necessary transport, this extension is architecturally compatible with the current design but is not implemented in the current prototype. As a data point supporting its feasibility, not as a security guarantee in itself: end-to-end frame processing latency on the receiver firmware was measured at 3–6 ms (preamble lock to full CRC-validated frame), suggesting there is ample timing margin to add a bounded round-trip check without a hardware redesign — but doing so, and validating it, remains future work (Section VII).

C. Comparison with RF-Based Alternatives

The total hardware cost of the prototype is approximately \$82 USD based on verified DigiKey unit pricing (Table II).

The single largest cost driver is the Texas Instruments PTN78000WAH DC-DC power module at \$24.58, selected for its wide input range and module-level integration convenience in the research prototype; a production design substituting a discrete buck regulator IC would reduce system cost to under \$60. By comparison, commercial LiFi systems (e.g., Signify Trulifi) are priced at several thousand dollars per access point, and RF-based physical layer security approaches require specialized antenna arrays, signal processing hardware, and environmental calibration. The open-source nature of both the firmware and the IoTAuth provisioning framework enables reproduction and extension by other researchers without licensing constraints.

More fundamentally, the system provides a security property — automatic revocation upon physical departure from the optical zone — that is structurally impossible to achieve with RF-based protocols without environmental modification. No amount of cryptographic sophistication in a WiFi-based system can prevent a device that has authenticated from retaining its credentials after leaving the room, because the RF signal itself does not respect room boundaries. The optical system achieves this property by construction, without any software-level revocation infrastructure.

D. Limitations

Several limitations of the current implementation should be acknowledged:

- 1) **Line-of-sight requirement.** The system requires an unobstructed optical path between sender and receiver. Environments with significant dust, fog, or vibration may experience intermittent frame loss, triggering unnecessary revocation if Δ is set too aggressively.
- 2) **No relay resistance (G3 not achieved).** As detailed in Section IV and Section VI, the current implementation enforces freshness (G1) and replay resistance (G2) but performs no round-trip timing check on the optical data path. A live relay that forwards genuinely fresh frames in real time, rather than resending captured stale bytes, would pass every check the receiver currently performs. Achieving relay-boundedness would require a distance-bounding challenge-response extension, which is not yet implemented.
- 3) **Single-channel reception.** Although the sender transmits on four LED channels simultaneously, the current receiver uses a single photodiode. Exploiting the spatial diversity of multiple receiver elements could improve robustness and enable angle-of-arrival estimation.
- 4) **Ambient light sensitivity.** Strong ambient light sources (direct sunlight, high-intensity discharge lamps) can saturate the photodiode or shift the operating point of the TIA, degrading reception quality. The programmable DAC threshold provides partial mitigation, but a fully adaptive threshold that tracks ambient conditions in real time is not yet implemented.
- 5) **No hardware key protection.** The RP2040 and RP2350 do not include a hardware security module or trusted

execution environment. Session keys stored in flash are extractable by an adversary with physical access and a debugger. Integration with a Trusted Platform Module (TPM) or secure element would address this limitation.

- 6) **Receiver key delivery is manual, not independently authenticated.** Unlike the sender, which acquires its session key over UART with HMAC-SHA256 challenge-response verification (Section III-C), the receiver’s copy is entered by an operator pasting hex output from the sender’s console into the receiver’s own console. This is adequate for a benchtop prototype but is not corroborated by a second, independent channel the way the sender’s key is — an operator error or a compromised console session could load an incorrect or stale key without detection.

VII. FUTURE WORK

Several extensions are planned or under consideration:

- 1) **Time-bounded key validity enforcement.** The IoTAuth session key structure includes absolute and relative validity fields (`abs_validity`, `rel_validity`) that are not yet enforced in firmware. Implementing these timers would enable automatic key expiration and re-provisioning, further limiting the window of exposure if a key is compromised.
- 2) **Formal protocol verification.** The security goals G1–G4 are amenable to formal verification using symbolic model checkers such as ProVerif or Tamarin Prover. Modeling the optical channel as a location-restricted link and verifying that the protocol satisfies freshness, replay resistance, and relay-boundedness under the stated adversary model would strengthen the theoretical foundations of this work.
- 3) **Multi-sender and multi-receiver environments.** Extending the system to support multiple overlapping optical zones, each with independent session keys and sender identifiers, would enable deployment in open-plan offices, warehouses, and multi-room facilities. The key identifier field in the existing flash block structure provides an architectural anchor for this extension.
- 4) **Independently authenticated receiver key delivery.** Automating receiver key acquisition — e.g., a networked host companion that retrieves the session key from IoTAuth over TLS once the receiver has decoded a key identifier from the sender, mirroring the sender’s own provisioning path — would replace the current manual console-paste step with a second, independently authenticated channel, removing the operator-trust dependency identified in Section VI-D.
- 5) **Adaptive threshold control.** Implementing a closed-loop control system that continuously adjusts the MCP4725 DAC threshold based on measured ambient light levels and signal amplitude would improve robustness across varying lighting conditions without manual calibration.
- 6) **Higher data rates.** Reducing the TIA feedback resistance to 47 k Ω or below with a matched feedback capacitor of 0.5–1 pF is expected to enable data rates of 2–4 Mbps. Beyond this, a dedicated high-bandwidth TIA IC and a second-stage amplifier would be required to approach the TLV3501’s 80 MHz toggle limit.
- 7) **Optical concentration and collection improvements.** The current prototype operates without any optical shaping on either the transmitter or receiver side. Future iterations will evaluate snap-in collimating lenses (e.g., Carclo 10413, 20–35° beam) on the LED array to narrow and direct the emission cone, improving range and reducing ambient light interference. On the receiver side, a compound parabolic concentrator (CPC) or Fresnel lens positioned over the SFH 2400-Z photodiode can increase the effective optical collection area by an order of magnitude, extending operational range without modifying the electronic signal chain. Reflective funnel structures mounted directly on the photodiode aperture are also under consideration to improve signal capture in diffuse or off-axis illumination conditions.
- 8) **Hardware key protection.** Integrating a TPM or secure element (e.g., ATECC608) for session key storage would prevent key extraction via physical access, addressing the most significant limitation of the current microcontroller-only implementation.
- 9) **Robotic platform demonstration.** The receiver PCB is already designed with Pololu 3pi+ robot integration headers and an onboard LiPo power system. Deploying the complete receiver on a 3pi+ platform and demonstrating that the robot executes commands only while continuously receiving authenticated optical frames — and halts immediately upon optical interruption — would provide a compelling physical demonstration of presence-based authorization in a mobile cyber-physical system context.

VIII. CONCLUSION

This work presents the design, implementation, and initial evaluation of a presence-based authorization system that uses LiFi optical communication as both a data channel and a physical security primitive. Unlike conventional authentication models — in which a device that has verified its identity retains access until explicitly revoked — the proposed system continuously binds authorization to the physical reception of authenticated optical frames, such that access is automatically revoked within a configurable time window Δ upon interruption of the optical path.

The system achieves authenticated encryption at 1 Mbps over a free-space optical link using AES-128-GCM on commodity microcontrollers (RP2040 and RP2350), with a custom analog front-end comprising an OPA381AIDGKT precision transimpedance amplifier, TLV3501AIDBVR high-speed comparator, and MCP4725A1T-E/CH programmable DAC threshold. Session keys are provisioned through the IoTAuth framework with HMAC-SHA256 challenge-response authentication

and persisted in a dual-slot flash architecture with SHA-256 integrity verification. A 64-entry nonce sliding window provides replay attack prevention, and the token validity window Δ bounds how long a captured, no-longer-live frame remains usable — a live relay of continuously fresh frames is not excluded by the current implementation and is reported as an explicit limitation (Section IV, G3).

The total hardware cost of the prototype is approximately \$82 USD at verified DigiKey unit pricing, demonstrating that presence-based optical authorization is achievable on resource-constrained embedded platforms without specialized or expensive hardware — remaining two orders of magnitude below commercial LiFi access point pricing. The analog front-end characterization reveals a quantifiable tradeoff between TIA bandwidth and operational range — a result that directly informs the design of future deployments.

By formalizing the security goals of freshness, replay resistance, relay-bounded authorization, and revocation on interruption, and by demonstrating enforcement of freshness, replay resistance, and interruption-revocation through a physical prototype — while identifying relay-boundedness as an explicit, unimplemented goal for future work — this work establishes that light itself — confined by physics, modulated by electronics, and authenticated by cryptography — can serve as a verifiable and continuously enforced proof of physical presence.

ACKNOWLEDGMENT

The authors thank KIM Labs at Arizona State University for providing the facilities and resources used in this work.

REFERENCES

- [1] A. D. Wyner, “The Wire-Tap Channel,” *Bell System Technical Journal*, vol. 54, no. 8, pp. 1355–1387, Oct. 1975.
- [2] S. Brands and D. Chaum, “Distance-Bounding Protocols,” in *Advances in Cryptology — EUROCRYPT ’93*, Lecture Notes in Computer Science, vol. 765, Springer, Berlin, 1994, pp. 344–359.
- [3] H. Haas, “Wireless data from every light bulb,” TEDGlobal, Edinburgh, July 2011.
- [4] A. Gomez, K. Shi, C. Quintana, M. Sato, G. Faulkner, B. C. Thomsen, and D. C. O’Brien, “Beyond 100-Gb/s Indoor Wide Field-of-View Optical Wireless Communications,” *IEEE Photonics Technology Letters*, vol. 27, no. 4, pp. 367–370, Feb. 2015.
- [5] IEEE, “IEEE Standard for Information Technology — Local and Metropolitan Area Networks — Specific Requirements — Part 11: Wireless LAN Medium Access Control (MAC) and Physical Layer (PHY) Specifications Amendment 7: Light Communications,” *IEEE Std 802.11bb-2023*, 2023.
- [6] G. Blinowski, “Security of Visible Light Communication systems — A survey,” *Physical Communication*, vol. 34, pp. 246–260, June 2019.
- [7] M. A. Arfaoui, M. D. Soltani, I. Tavakkolnia, A. Ghayeb, M. Safari, C. Assi, and H. Haas, “Physical Layer Security for Visible Light Communication Systems: A Survey,” *IEEE Communications Surveys & Tutorials*, vol. 22, no. 3, pp. 1887–1908, 2020.
- [8] S. Cho, G. Chen, and J. P. Coon, “Securing visible light communication systems by beamforming in the presence of randomly distributed eavesdroppers,” *IEEE Trans. Wireless Commun.*, vol. 17, no. 5, pp. 2918–2931, May 2018.
- [9] M. Caputo, L. Mucchi, and L. Pierucci, “Multi-RIS Aided VLC Physical Layer Security for 6G Wireless Networks,” *IEEE Transactions on Mobile Computing*, 2024.
- [10] I. U. Zaman, A. B. Lopez, M. A. Al Faruque, and O. Boyraz, “A Physical Layer Security Key Generation Technique for Inter-Vehicular Visible Light Communication,” in *Advanced Photonics Congress (IPR, Networks, NOMA, PS, SPPCom)*, OSA Technical Digest, paper SpTu1F.3, 2017.
- [11] Y. M. Al-Moliki, M. T. Alresheedi, and Y. Al-Harathi, “Secret Key Generation Protocol for Optical OFDM Systems in Indoor VLC Networks,” *IEEE Photonics Journal*, vol. 9, no. 2, pp. 1–15, Apr. 2017.
- [12] M. S. Hossain et al., “Secure Quantum Key Distribution Over VLC Networks for Next-Generation Smart Cities,” *Int. J. Networked Distrib. Comput.*, 2025.
- [13] T. Perković, M. Čagalj, and T. Kovačević, “LISA: Visible light based initialization and SMS based authentication of constrained IoT devices,” *Future Generation Computer Systems*, vol. 97, pp. 775–791, Aug. 2019.
- [14] S.-M. Kim, “Secure Visible Light Communication Technique Based on Asymmetric Data Encryption for 6G Communication Service,” *Electronics*, vol. 9, no. 11, p. 1847, Nov. 2020.
- [15] T.-L. Liao, C.-Y. Chen, H.-C. Chen, Y.-Y. Chen, and Y.-Y. Hou, “Realization of a Secure Visible Light Communication System via Chaos Synchronization,” *Mathematical Problems in Engineering*, vol. 2021, Feb. 2021.
- [16] Signify N.V., “Trulifi: High-speed Internet using your lights with LiFi,” 2024. [Online]. Available: <https://www.signify.com/global/innovation/trulifi>
- [17] Oledcomm S.A.S., “LiFi Technology for Cybersecurity Solutions,” 2024. [Online]. Available: <https://www.oledcomm.net/solutions/cybersecurity/>
- [18] LiFi Lab, “LiFi Secure Access Control System,” 2024. [Online]. Available: <https://lifi-lab.com/tecnologia-lifi/lifi-secure-access-eng/>